

Relatório de Investigação SOC

Análise de E-mails Maliciosos — Dataset email_lab_dataset

Analista: Eric Kinoshita | **Data:** 2026-05-04 | **Total de amostras:** 28 .eml

1. Sumário Executivo

Foram analisados **28 e-mails** em formato *.eml*, coletados de um dataset de laboratório. A análise envolveu inspeção manual de cabeçalhos, validação de SPF/DKIM/DMARC, extração de URLs e identificação de anexos. Dos 28 e-mails: **27 são maliciosos** (26 phishing/spoofing e 1 com anexo malware) e **1 é legítimo** (controle, Proton Mail). A campanha demonstra técnicas combinadas de spoofing de marca, typosquatting de domínio e linguagem de urgência.

Classificação	Quantidade
Legítimo	1
Malicioso (Phishing + Malware)	1
Malicioso (Phishing/Spoofing)	26
TOTAL	28

2. Metodologia — Passo a Passo da Investigação

Passo 1 — Coleta e preservação

Os arquivos foram extraídos do ZIP *email_lab_dataset.zip* (senha: **blueTeam**) e mantidos em pasta isolada *read-only*. Nenhum link ou anexo foi executado; toda análise é estática.

Passo 2 — Triagem inicial (SOC N1)

Para cada *.eml* verificamos: (a) coerência entre **From** e **Return-Path**; (b) presença de linguagem de urgência no **Subject**; (c) qualidade visual do remetente (typosquatting). E-mails que falham em qualquer um destes pontos vão para análise técnica.

Passo 3 — Análise técnica de cabeçalho (SOC N2)

Inspeção da cadeia **Received** (de baixo para cima = origem real até destino) e do bloco **Authentication-Results**. Critérios: **SPF=fail/softfail**, **DKIM=fail/none**, **DMARC=fail** indicam spoofing. IPs em faixas RFC1918 (10/8, 172.16/12, 192.168/16) ou TEST-NET (192.0.2/24, 198.51.100/24, 203.0.113/24) em servidores públicos são impossíveis e confirmam forja.

Passo 4 — Análise de URL

URLs do corpo HTML são extraídas via regex e o **domínio efetivo** (eTLD+1) é avaliado da direita para a esquerda. Exemplo: em *secure-login.microsoft.verify-user.ru*, o domínio real é *verify-user.ru* — tudo antes é subdomínio sob controle do atacante.

Passo 5 — Análise de anexo (SOC N2/N3)

Anexos são identificados via **Content-Disposition: attachment**. Extensões perigosas (*.htm*, *.html*, *.exe*, *.scr*, *.js*, *.vbs*, *.hta*, *.docm*, *.xlsm*, *.lnk*) elevam para classificação **malware**. No caso *caso1.eml*, o anexo *SilvaoPostACTIONREQUIRED.htm* em base64 contém JavaScript que decodifica e injeta um formulário falso de captura de credenciais (*document.write(unescape(atob(b64))))*).

Passo 6 — Consolidação de IOCs

Indicadores extraídos (IPs, domínios, padrões de subject) são compilados para alimentar regras de bloqueio em firewall, proxy, SIEM e mail gateway, conforme tabela na seção 5.

Passo 7 — Resposta e contenção (SOC N3 / IR)

Ações recomendadas: (1) quarentena dos e-mails ativos via *Compliance Search* (M365) ou equivalente; (2) bloqueio de IPs e domínios; (3) reset de credenciais e revogação de tokens MFA dos usuários que clicaram; (4) varredura EDR nos endpoints expostos; (5) ativação de DMARC **p=reject** no domínio próprio para impedir spoofing inverso.

3. Tabela Completa de E-mails Analisados

Resultado da execução do script *analyze_emails.py* sobre o dataset. Cores: **vermelho** = phishing+malware, **laranja** = phishing/spoofing, **verde** = legítimo.

#	Arquivo	From	IP	SPF	DKIM	DMARC	Classificação
1	caso1.eml	Silvao Post Webmail <no-reply@silva...	109.205.120.0	none	none	none	Phish+Malware
2	e-mail_estudo_de_caso.eml	Itaú Suporte <suporte@itau-cliente....	192.168.0.45	fail	fail	-	Phishing
3	header_fake.eml	Apple Suporte <admin@apple-support....	10.0.0.23	softfail	fail	-	Phishing
4	secreto.eml	webinaraofd <webinaraofd@protonmail.c...	185.70.43.24	pass	pass	pass	Legítimo
5	email_1.eml	Support 1 <support1@fake-domain1.co...	185.199.1.10	fail	none	fail	Phishing
6	email_10.eml	Support 10 <support10@fake-domain10...	185.199.10.10	fail	none	fail	Phishing
7	email_11.eml	Support 11 <support11@fake-domain11...	185.199.11.10	fail	none	fail	Phishing
8	email_12.eml	Support 12 <support12@fake-domain12...	185.199.12.10	fail	none	fail	Phishing
9	email_13.eml	Support 13 <support13@fake-domain13...	185.199.13.10	fail	none	fail	Phishing
10	email_14.eml	Support 14 <support14@fake-domain14...	185.199.14.10	fail	none	fail	Phishing
11	email_15.eml	Support 15 <support15@fake-domain15...	185.199.15.10	fail	none	fail	Phishing
12	email_16.eml	Support 16 <support16@fake-domain16...	185.199.16.10	fail	none	fail	Phishing
13	email_17.eml	Support 17 <support17@fake-domain17...	185.199.17.10	fail	none	fail	Phishing
14	email_18.eml	Support 18 <support18@fake-domain18...	185.199.18.10	fail	none	fail	Phishing
15	email_19.eml	Support 19 <support19@fake-domain19...	185.199.19.10	fail	none	fail	Phishing
16	email_2.eml	Support 2 <support2@fake-domain2.co...	185.199.2.10	fail	none	fail	Phishing
17	email_20.eml	Support 20 <support20@fake-domain20...	185.199.20.10	fail	none	fail	Phishing
18	email_21.eml	Support 21 <support21@fake-domain21...	185.199.21.10	fail	none	fail	Phishing
19	email_22.eml	Support 22 <support22@fake-domain22...	185.199.22.10	fail	none	fail	Phishing
20	email_23.eml	Support 23 <support23@fake-domain23...	185.199.23.10	fail	none	fail	Phishing
21	email_24.eml	Support 24 <support24@fake-domain24...	185.199.24.10	fail	none	fail	Phishing
22	email_3.eml	Support 3 <support3@fake-domain3.co...	185.199.3.10	fail	none	fail	Phishing
23	email_4.eml	Support 4 <support4@fake-domain4.co...	185.199.4.10	fail	none	fail	Phishing
24	email_5.eml	Support 5 <support5@fake-domain5.co...	185.199.5.10	fail	none	fail	Phishing
25	email_6.eml	Support 6 <support6@fake-domain6.co...	185.199.6.10	fail	none	fail	Phishing
26	email_7.eml	Support 7 <support7@fake-domain7.co...	185.199.7.10	fail	none	fail	Phishing
27	email_8.eml	Support 8 <support8@fake-domain8.co...	185.199.8.10	fail	none	fail	Phishing
28	email_9.eml	Support 9 <support9@fake-domain9.co...	185.199.9.10	fail	none	fail	Phishing

4. Achados de Destaque

4.1. *caso1.eml* — *Phishing com Credential Harvester*

E-mail spoofando **SilvaoPost** (silvao.br), enviado pelo serviço público **emkei.lv** (109.205.120.0) — comum para fraudes anônimas. Reply-To aponta para *postsilvao.br*, não para o From, capturando respostas em domínio do atacante. Anexo *.htm* em base64 decodifica para JS que escreve formulário falso e envia credenciais via POST. Header customizado *X-Custom-Header: RkIBUHtlYXN5X2hiYWwRlcnN9Cg==* decodifica em base64 para a flag **FIAP{easy_headers}**.

4.2. *e-mail_estudo_de_caso.eml* — *Itaú Spoof*

Falsifica o Banco Itaú via typosquatting **itau-cliente.com**. A linha *Received* registra origem **192.168.0.45** — IP privado (RFC 1918) que jamais aparece em tráfego SMTP legítimo na internet pública. SPF=fail e DKIM=fail confirmam.

4.3. *header_fake.eml* — *Apple Spoof*

Spoof Apple via **apple-support.com** + **mail.fakeapple.com**. IP **203.0.113.5** pertence à faixa **TEST-NET-3 (RFC 5737)**, reservada para documentação — qualquer e-mail com origem nessa faixa é, por definição, forjado. SPF=softfail, DKIM=fail.

4.4. *email_1 a email_24* — *Campanha em massa*

24 e-mails idênticos em padrão, variando apenas o índice N. From *support{N}@fake-domain{N}.com*, Return-Path *attacker{N}@evil.com*, IP *185.199.{N}.10*, URL *http://malicious{N}.com/login*. Todos com SPF=fail, DKIM=none, DMARC=fail. Caracteriza simulação de campanha automatizada para treinamento de detecção em volume.

4.5. *secreto.eml* — *Controle (legítimo)*

Único e-mail legítimo do dataset. Enviado via Proton Mail (185.70.43.24), com SPF=pass, DKIM=pass, DMARC=pass, ARC-Seal validado pelo Google. Serve de baseline para comparação com as demais amostras.

5. IOCs Consolidados

Lista pronta para importação em SIEM, firewall, proxy ou plataformas de Threat Intelligence. Recomenda-se validar IPs antes de aplicar em produção (a faixa 185.199.x.x na vida real pertence ao GitHub Pages — neste laboratório é fictícia).

Tipo	IOC	Origem
IP	185.199.1.10 a 185.199.24.10	email_1 a email_24
IP	109.205.120.0	caso1.eml (emkei.lv)
IP	192.168.0.45 (RFC1918)	e-mail_estudo_de_caso.eml
IP	203.0.113.5 (TEST-NET)	header_fake.eml
IP	10.0.0.23 (RFC1918)	header_fake.eml (interno)
Domínio	evil.com / evil1-24.com	email_1 a email_24 (Return-Path)
Domínio	fake-domain1-24.com	email_1 a email_24 (From)
Domínio	malicious1-24.com	email_1 a email_24 (URL)
Domínio	itau-cliente.com	Typosquatting Itaú
Domínio	apple-support.com / fakeapple.com	Typosquatting Apple
Domínio	silvao.br / postsilvao.br	Spoof SilvaoPost
Domínio	emkei.lv	Mailer público anônimo
Domínio	evilparrot.thm	Credential harvester (caso1)
Subject	Urgent Action Required #*	Padrão massivo
Subject	URGENTE: Revalidação de Token	Itaú spoof
Subject	URGENT: SilvaoPost Account Update	caso1.eml
Subject	[Alerta de segurança] Apple	header_fake.eml

6. Query de Detecção (Splunk)

```
index=email sourcetype=mail
| eval auth_failed=if(
  match(spfb,"fail") OR
  match(dkim,"fail") OR
  match(dmarc,"fail"), 1, 0)
| eval suspicious_subject=if(
  match(Subject,"(?i)urgent|urgente|alerta|verify|invoice|payment|token|bloquear"), 1,
0)
| where auth_failed=1 OR suspicious_subject=1
| stats count BY sender, src_ip, recipient
| sort - count
```

7. Conclusão

O dataset confirma os principais vetores de phishing observados em ambientes corporativos: **autenticação SMTP ausente ou falhando**, **typosquatting de marcas confiáveis**, **linguagem de urgência** e **credential harvesters** entregues como anexo HTML. A defesa efetiva exige camadas combinadas: políticas DMARC restritivas, sandbox de anexos, treinamento de usuários e bloqueio proativo dos IOCs identificados. O modelo de classificação aplicado neste relatório (SPF/DKIM/DMARC + análise de domínio + inspeção de anexo) acertou 100% das 28 amostras quando confrontado com a inspeção manual.